

LABORATORIES
AUDIT PROGRAM #50-05-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
June 2026	All	All	Jessica Lin	Created audit program

LABORATORIES
AUDIT PROGRAM #50-05-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment	4
PLANNING: Data Analysis	5
PLANNING: Self-Service Report	7
PLANNING: Reference Material	8
PLANNING: Fraud Template	9
CONTROL ASSESSMENT QUESTIONS	10
Key Control Question: 1. Trade Compliance - Exports Regulation	10
Primary Test: Trade Compliance - Exports Regulations (TC001.P)	11
Key Control Question: 2. Access Management, Data Privacy, and Data Security	12
Primary Test: Access Management (AD001.P)	13
Primary Test: Workplace Security (AD002.P)	14
Primary Test: Data Privacy and Security (AD003.P)	15
Key Control Question: 3. Product Development and Research Projects	16
Primary Test: Product Development & Research Projects (PD001.P)	17
Key Control Question: 4. Government Operations	18
Primary Test: Government Operations (GO001.P)	19
Key Control Question: 5. Financial Management	20
Primary Test: Intercompany Recovery Rates (FM001.P)	21
Primary Test: Internal Billing (FM002.P)	22
Primary Test: Ledger Review (FM003.P)	23
Primary Test: Over/Under Recovery Process (FM004.P)	24
Primary Test: Department Expenses (FM005.P)	25
Primary Test: Other income and/or charges (FM006.P)	26
Key Control Question: 6. Asset Management	27
Primary Test: Asset Management (AM001.P)	28
Key Control Question: 7. Procurement	29
Primary Test: Procurement (PR001.P)	30

LABORATORIES AUDIT PROGRAM #50-05-00

PROCESS AND OBJECTIVE

There are three types of laboratories (labs) included in the audit program: IBM Research, Software Labs, and IBM Infrastructure Labs.

IBM Research has a mission to create the next advances in computing technology. Research labs investigate and research key areas for IBM to drive innovation and impact on our technology pillars and horizontal strategies. Research labs do not develop products; however, they perform research projects based on IBM's strategy defined globally, customer requests or inputs coming from other business units, either through commercial contracts or internal documents of understanding (DOUs), to quickly transition the innovations developed into market-ready, client-focused solutions.

Software Labs' mission is to accelerate innovation into products to drive software revenue growth, establish IBM as the leader in Enterprise Data and Automation for the artificial intelligence (AI) era, and create innovations that unlock new markets and product categories. Software Labs are located across key global hubs, bringing together exceptional technical talent to design, build, and deliver IBM's products. Working in cross-geography teams, the developers collaborate closely with Product Managers to turn innovation into enterprise-ready solutions used by clients worldwide.

IBM Systems Lab, also known as IBM Infrastructure Lab, is dedicated to creating innovative hardware and software solutions for enterprise computing. Its mission revolves around developing cutting-edge technologies that enhance performance, efficiency, reliability, and security while fostering open collaboration with industry partners and academic institutions. The lab focuses on supporting hybrid cloud and AI workloads and driving standards and interoperability to empower businesses in the digital era.

Nuances of Auditing Laboratories

It is important that the audit team lead (ATL) contact the focal point as soon as possible to understand the unique processes that are held separately for the lab(s), and the particular process steps that each lab could have (most labs do not develop products but are part of a development and production chain). There is no rule for this, and the ATL may apply his/her best judgement and consult with the internal audit focal point to discuss possible audit scopes.

When conducting an integrated audit, the audit team lead should use IT audit protocols and make evaluations under IT audit for the risk area of Access Management, Data Privacy, and Security to avoid duplication.

For trade compliance, internal auditors will assess the design and operating effectiveness of IBM's policies, procedures, and controls established to address regulatory and trade compliance. While Legal retains responsibility for determining actual compliance, our scope—guided by the audit charter and the Institute of Internal Auditors standards—focuses on testing whether the established processes are consistently applied and function as intended. If potential compliance issues arise, please consult Export Regulation Office and Trade Counsel.

LABORATORIES
AUDIT PROGRAM #50-05-00

PLANNING: Audit Program Risk Alignment

Laboratories

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Trade Compliance	High	Trade Compliance	TC001.P
Access Management, Data Privacy, and Security	High	Access Management, Data Privacy, and Security	All
Product Development and Research Projects	Medium	Product Development and Research Projects	PD001.P
Government Operations	Medium	Government Operations	GO001.P
Financial Management	Medium	Financial Management	All
Asset Management	Low	Asset Management	AM001.P
Requests to Procurement	Low	Procurement	PR001.P

LABORATORIES AUDIT PROGRAM #50-05-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The Data Analysis engagement procedures in the Audit Manual (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Concern
Procurement - Universe of all invoices paid during the audit period - Universe of all purchase orders (POs) - Universe of all non-PO transactions	Review PO and payment data: Review invoices with POs raised close to or after invoice dates.	- Lack of procurement involvement may increase costs. - Contracts were not in place when needed to meet the project schedule. - Unidentified bypasses may result in fraud or further financial to legal exposure.
Asset Management Hardware: a full inventory of: - Assets owned by IBM - Assets managed by IBM that are owned by the customer or a third party Software: a full list of software assets, including details of: - Software vendor - Number of licenses purchased and deployed - Maintenance agreements in place - Most recent reconciliation of software assets	Hardware: - Concentration of assets (by value and by volume) - Locations subject to recent move of assets - Locations used for multiple projects - Storage and stockroom locations at IBM or customer sites Software: - Software alert type (which would identify non-compliant licenses) - Time frame to close software alerts (alerts which remained open for more than 180 days) - Alerts which were manually closed	- Insufficient or untimely asset tracking could result in undetected asset or information loss, inaccurate financial reporting, low performance due to unavailability when needed. - Inappropriate and undetected use of software licenses could result in financial exposure and legal exposure.
Access Management Obtain a list of all employees/contractors who left the projects or IBM during the audit period, including access granted and access removal details.	Inappropriate access: access after job change or separation; inadequate level of access.	Ineffective access control process could expose confidential information, which may negatively impact IBM competitive position.

LABORATORIES
AUDIT PROGRAM #50-05-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Concern
Financial Management - Manual entries - request detailed ledger extract for all manual entries - Balance sheet account reconciliations - request list of all balance sheet accounts reconciled	Review ledger entries report paying attention to material manual deferrals and accruals; manual reversals; manual credits and provisions. Perform analysis based on variance, balances, and the timing reconciliations were performed; compare the same reconciliations across periods.	- Unsupported accounting entries, with insufficient review may lead to inaccurate financial records. - Lack of sufficient documentation to explain and resolve variances could lead to financial misstatements.
Billing Universe of all billing/invoices issued during the audit period	Select a sample of billing/invoices: - Excessive delays - Duplicate amounts - Outstanding/unpaid billing/invoices	Untimely or inaccurate billing could have negatively impact on cash flow and financial recording.
Compliance with Transportation Entertainment, and Business Amenities (CTEBA) Obtain the following reports: - Concur expenses submissions during the audit period. - The official CTEBA approval tool, a universe report of all CTEBA requests submitted for approval during the audit period showing all available fields.	- Approvals were timely provided, based on a valid business reason and supporting documentation - Exceptions were reviewed and approved by management - Pre-approvals were obtained when applicable - Expenses were accurately categorized. - Government Owned Entities (GOEs) and Commercial Parties in Certain Countries ("CPICC") customers were properly identified, and CTEBA rules were followed. (Entity Identification, attendee collection and amenity definition, confirmation letter and post interaction activities) For additional information refer to Audit Program 18-05-00.	Non-compliance with CTEBA process coupled with insufficient monitoring over disbursements could result in violation of US Foreign Corrupt Practices Act (FCPA), fraud, bribery, financial loss, and impact to IBM's reputation.

LABORATORIES
AUDIT PROGRAM #50-05-00

PLANNING: Self-Service Report

Some information previously included in the Initial Data Request (IDR) items which continue to be relevant information in audits will now be extracted directly by the audit team. These are as follows:

Information previously in IDR	Instructional materials to download information
• Management Self-Assessment of Controls (MSAC) • Risk Evaluations (RE's) • Proactive Business Control Reviews • (No key controls)	Login to OpenPages Risk, Controls and Assurance . Open User menu in top right, select Finance Business Controls (FBC) General User as profile, Open Primary menu in top left, select "Organization", and select "Processes" and then select the applicable criteria (Product Development or Research) to get the results.

LABORATORIES AUDIT PROGRAM #50-05-00

PLANNING: Reference Material

IBM Conduct Guidelines

- Business Conduct Guidelines (BCG): <https://w3.ibm.com/ibm/corporate-documents/business-conduct-guidelines>
- Compliance with Transportation, Entertainment, and Business Amenities (CTEBA): <https://w3.ibm.com/w3publisher/cteba>
- IBM Technical Ethics Guidelines – Global: <https://w3.ibm.com/ibm/corporate-documents/business-conduct-guidelines/ibm-technical-ethics-guidelines-global>

Corporate Policy

- Corporate Policy 103B: Business Conduct and Ethics <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-103>
- Corporate Policy 130: IBM Data Privacy Policy <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-130>

Corporate Instructions

- FIN 101 Control of Disbursements: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>
- FIN 151 Application Systems Control and Auditability (ASCA) <https://w3.ibm.com/ibm/corporate-documents/fin/fin-151>
- FIN 168/LEG 168 Business Amenities and Gifts: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-168-leg-168>
- FIN 183 Separation of Duties (SOD): <https://w3.ibm.com/ibm/corporate-documents/fin/fin-183>
- LEG 116 Classification and control of IBM information: <https://w3.ibm.com/ibm/corporate-documents/leg/leg-116>
- PROC167 Vendor Sourced Labor Services: <https://w3.ibm.com/ibm/corporate-documents/proc/proc-167>

General Data Protection Regulation (GDPR)

- GDPR Readiness: <https://www.ibm.com/data-responsibility/gdpr/#4>
- Compliance, Audit, Risk Mitigation and Management: <https://w3.ibm.com/w3publisher/dprc>
 - Guidance on Personal Information (PI) and Sensitive Personal Information (SPI)
 - Privacy Impact Assessment (PIA)

Other useful links

- IBM Product Development Life Cycle (PDLC): <https://w3.ibm.com/w3publisher/winning-products/how-we-work/product-development-lifecycle>
- US Export Regulations Program (USERP): <https://w3.ibm.com/w3publisher/ibm-export-regulation-office/us-export-regulations-program-userp>
- Research: <https://w3.ibm.com/w3publisher/ibm-research>
- Software Innovation Lab: <https://w3.ibm.com/w3publisher/sil>
- IBM Systems Online Collaboration Environments (OCEs): <https://w3.ibm.com/w3publisher/ibm-systems-biso/reference-and-guidance/business-operations/online-collaboration-env>
- Research Export Regulations (including OCEs): <https://w3.ibm.com/w3publisher/research-finance-operations/export#OCE>
- Legal Information System - International Transactions - Intercompany Agreements (ICA): <https://w3.ibm.com/w3publisher/ica-bratislava/our-instructions/ica-guidance>
- Accounting Policy and Financial Reporting: <https://w3.ibm.com/w3publisher/accounting-policy-financial-reporting>
- Services Accounting Instructions: <https://w3.ibm.com/w3publisher/accounting-policy-financial-reporting/accounting-instructions>
- IBM Safety Standards: <https://w3.ibm.com/w3publisher/ibm-global-safety/safety-standards>
- Information Technology Security Standards (ITSS): <https://pages.github.ibm.com/ciso-psg/main/standards/itss.html#31-general-user-responsibilities>
- Denied Parties List (DPL) and Unauthorized Supplier List (USL): <https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/dpl-and-usl>
- IBM Corporate Security Policy (ICSP): <https://w3.ibm.com/w3publisher/icsp/ibm-corporate-security-policy>

LABORATORIES
AUDIT PROGRAM #50-05-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and results in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Conflict of interest	Activities performed by employees should be assessed by management to detect possible conflicts of interest	Risks related to separation of duties have been periodically (at least annually) assessed and documented by management to identify conflicts with remediation actions. When testing access management, focus at least on approve and update accesses.
Falsification of records/documents	Documentation accuracy	Supporting documentation should be valid, accurate, and approved at the time of the transaction posting. There should not be inconsistencies on chronology and types of letters.
Exposure of IBM or customer/supplier information to unauthorized access	Information was timely and correctly classified, and protected as designed	There are several tests in this area, for physical as well as internet data, workplace security, device security, encryption, access management, and control access systems testing.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Trade Compliance - Exports Regulation

Objective:

To confirm that IBM products, technology, and services to be exported, re-exported, or delivered were properly classified prior to export and the appropriate licenses were obtained. Classification must be communicated by the controlling development and research organization to all other development and research organizations collaborating with development projects.

To verify compliance with the Export Regulation Office (ERO) United States Export Regulation Program (USERP) requirements, and corporate and local procedures governing export compliance requirements.

This applies to all products, cryptographic, non-cryptographic, defense related, etc. This also includes software and technology introduced into a development organization, Online Collaboration Environments (OCE). OCEs include databases, web pages, web casting, murals, slack channels, Trello boards, servers that can be accessed remotely, distributed development environments, distributed file systems, and tools with data repositories, etc. plus external and internal cloud environment for international development project collaboration and discussion.

Risk/Exposure:

Failure to comply with IBM's export regulation requirements could lead to delays in projects or movements of goods, employees, or visitors; fines and penalties; and potential loss of IBM's export privilege.

LABORATORIES AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. 1. Trade Compliance - Exports Regulation

Primary Test: Trade Compliance - Exports Regulations (TC001.P)

Objective:

To confirm that IBM products, technology, and services to be exported, re-exported, or delivered were properly classified prior to export and the appropriate licenses were obtained. To verify technologies were communicated, exposed, released or transferred to or in the presence of foreign persons working in countries in which they are not citizens or legal residents.

There are two main tests to be performed for Export Regulations for laboratories:

- The classification and regulation for the products or projects being worked for non-US Labs
- The classification of the OCEs, the tools used for developing activities across countries.

Approach:

- Select a sample of products/projects to validate the ERO classification and appropriate evaluation was done prior to the start of the work in the non-US country.
 - Were Export Classification Control Number (ECCN) and Export Classification accurate?
 - Was the annual revalidation of ECCN performed? Were appropriate actions taken for ECCN change incurred?
 - Were ERO review performed before the project started?
 - Was the list of employees who were working for the project maintained?
 - Was the purpose of the import or export clarified with supporting evidence?
 - Was the import approved by management? Was the export reviewed by ERO?
 - Were the import products clarified in the import permission sheet?
 - Were the export products clarified in the export approval notice?
 - Was the correct Harmonized Tariff Schedule (HTS) code used?
 - Was the asset system record updated timely?
- Select a sample of the OCEs to validate their appropriate and timely export classification. Also, validate if there were proper controls over the OCEs inventory and accesses.
 - Was there any dated evidence of OCE owner's instructions to get a U.S. export license and signed non-disclosure agreement (NDA) before granting access?
 - Was there any evidence of sending NDA notification?
 - Was there any evidence of documentation for acceptance and signed NDA?
 - Was access implemented in accordance with the export classification?
 - Was access limited and deleted for the leavers?
- Validate if required approval from ERO was obtained before hiring or accepting a move-in of foreign employee.
 - Was a NDA signed by the employee if required by the process?
 - Was the employee's access to projects/data appropriately controlled based on the export classification level?
- Validate if mandatory export control training was completed by the required employees and the education participation records for designated persons were retained properly per USERP section 2.
- Review that the IBM operating unit has implemented procedures to ensure site visits by foreign nationals were appropriately assessed, prior to the visit occurring, for any deemed export/re-export considerations that may apply. These evaluations should be based on the IBM host's knowledge of their visitors and the classification of the technology and/or source code which would be accessed during their visit.
 - Were all required information maintained in the visitor list?
 - Was the color zone accurate?
 - Was the denied party list confirmed?
 - Was the Diversion Risk Profile confirmed?
 - Was ECCN accurate?
 - For visitors requiring ERO review, were approvals obtained before accepting the visitors?
 - Was there approval of the visit?

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Access Management, Data Privacy, and Data Security

Objective:

To verify that a process is in place to safeguard data that was reviewed or stored as part of development and research. To ensure that access to the required systems was controlled in a timely manner and to prevent unauthorized access to applications and information. To determine if appropriate management approvals were granted and documented according to business need. To ensure adherence to ITSS Chapter 3: End user Acceptable Use Requirements, 3.1 General User Responsibilities.

Risk/Exposure:

Unauthorized persons may gain access to the application and its resources enabling them to get access to privileged and confidential IBM information which may result in IBM competitive data exposure.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Access Management, Data Privacy, and Data Security

Primary Test: Access Management (AD001.P)

Objective:

To verify that management controls and authorization of all access to the application and data could be demonstrated with management awareness and alignment with contractual requirements and IBM standards as guidelines and best practices. This include but not limited to verify that

- removal of such access was processed when there is no longer a business justification
- valid business needs, controls, audit trails for privileged user IDs existed and was current.
- accountability for shared user IDs could be established (when applicable)
- processes were implemented to perform application security assurance reviews
- sensitive programs and associated sensitive data were identified and protected accordingly, including proper authorization for access and use

Approach:

ASCA

Review the list of all applications and databases used in the developing, testing, support, and researching activities and determine if all necessary ASCA certifications were in place for IBM applications, databases, and spreadsheets used as a trusted source of information. (when applicable)

Access Control

- Review access control lists to validate business needs and periodic continued business needs (CBN) were appropriately performed per IBM or customer (when applicable) requirements:
 - Defined business needs criteria to access application user profiles and data
 - Procedures for the removal of access and password resets
 - Procedures for privileged user ID access management and audit trails maintenance
 - Procedures for the periodic revalidation of users' CBN
 - Procedures for quarterly employment verification
 - Procedures for maintaining a log of individual accountability for usage of shared user IDs
 - Clear documentation of the control points within the access management process
 - Appropriate approval by management or customer representative
 - Ensure privacy assessments have been done on customer data with appropriate controls
 - Ensure problem data has been analyzed for customer sensitive information and properly protected
- For systems used for confidential development and research activities, were controls in place to guarantee physical and logical security?
- Validate the access list to the firewall of the lab system's network and make sure only lab employees with business should have access to this firewall.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Access Management, Data Privacy, and Data Security

Primary Test: Workplace Security (AD002.P)

Objective:

To ensure that controls were in place to safeguard proprietary, sensitive, and personal information against unauthorized disclosure in an environment where lab employees work. All scope areas below need to be compared to contractual requirements for IBM (when applicable).

Approach:

Review workstation security procedures and monitoring.

Review workplace security procedures and perform onsite inspection if necessary. Inspection of work area to ensure that IBM or customer (when applicable) confidential data is secured. They should include the following inspections:

- Unprotected documents that contain classified IBM or customer confidential information
- Unprotected personal information about former, prospective, and current employees (information someone has about someone else)
- Unprotected personal information about customers and suppliers
- Unclaimed IBM Confidential information, or other sensitive output located on printers, copiers, in nearby output racks, confidential disposal units, or recycle bins which were accessible to general site users (e.g., in IBM internal space which can be accessed by anyone with a general access badge for the site, or in a secured area to which there is also general access). Also review the policies and procedures for the removal or disposal of material in confidential disposal units. If bins were used, select a sample of bins for inspection as to their integrity (locks, hinges, etc.)
- Unprotected workstations (e.g., workstations with no power-on or screen-saver password). When workstations are found to be running after hours, they should not be powered down until the reviewer has established that there is not a critical business need for them to be running
- Unsecured laptops, portable peripherals, and other handheld devices
- Unprotected computer media (e.g., diskettes, CD-ROMs/DVD-ROMs, hard drives, extra computer equipment, etc.) that are labeled IBM Confidential

For accounts where lab employees connect their laptops to the customer networks, ensure ITCS303 is being followed for encryption of IBM Confidential data. Also, ensure customer data is being protected.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Access Management, Data Privacy, and Data Security

Primary Test: Data Privacy and Security (AD003.P)

Approach:

Data Security

- Validate that there were controls to certify that IBM was sufficiently protecting confidential information.
- Review documentation to ensure proper classification of information. For this, review possible open access repositories.
- Review the approved IT security guidelines in place for the organization (indicate if ITSS is in place). The reason for requesting it is that ITSS is open and summarized to let the organizations implement their own specifics controls.
- Request the IP range(s) reserved for and/or available to the Lab. From this, the Business Intelligence and Technology team can run different tests to check their compliance with the IPs documentation/registration, validate if they are behind firewall (this is important for labs that handle isolated systems), and validate access (if it is default IDs, if it is open, possibly old (vulnerable) software in use, etc.).

Data Privacy

Review the Data Privacy responses provided to determine if IBM is Controller or Processor of personal information (PI)/sensitive personal information (SPI) data in the process.

- IBM as a Controller – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of PI. That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- IBM as a Processor – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client PI and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

If IBM is **Controller**, request a risk-based sample of PIA for the processes and/or assets. Complete the testing based on the latest CA&AS education.

If IBM is **Processor**, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing based on the latest CA&AS education.

If IBM is **both Controller and Processor**, test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Product Development and Research Projects

Objective:

To determine whether controls were put in place to ensure that there was an appropriate project management system and that project deliverables were properly executed, tracked, and reported according to the guidelines and agreements.

Risk/Exposure:

Inadequate controls over product development could lead to legal exposure, unauthorized work initiation, inaccurate product costing, and damage to IBM's image.

Inadequate review of agreements or contracts could expose IBM to reputational damage and financial loss.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Product Development and Research Projects (when applicable)

Primary Test: Product Development & Research Projects (PD001.P)

Objective:

To determine whether controls were put in place to ensure that there was an appropriate project management system and that project deliverables were properly executed, tracked, and reported according to the guidelines and agreements.

Approach:

- Select a sample of local projects that are part of the overall product development process to test
 - Was an agreement in place before development work started or before its expiration?
 - Were the product release features properly documented and implemented as agreed?
 - Was monitoring of the product development sufficient to ensure timely product release?
- Select a sample of products released within the audit period and in which the product development was performed by the lab to verify the effectiveness of methodology/process used by the product and release management.
 - Were all planned tests executed prior to the release?
 - Were the checkpoints and artifacts matching the requirements of the release type?

Note: [Oasis](#) is an IBM internal release management application for product teams to track and manage all of their release management activities
- For the selected product development projects, review:
 - The evidence of the requested product release features by the Product Owner/Offering Manager.
 - Evidence of the development monitoring (design and coding) for the above product features.
 - Required quality checks and reviews were completed prior to the software release.
 - Open-source components and third-party intellectual property used had proper attribution or licensing.
 - Security checks were performed prior to sharing any software trial versions to external parties.
 - Any change in the original features.
- If the Lab also had Level 3 support, from a list of all the problem analysis (PMR/tickets), select a sample to validate the timelessness of the action plan/steps taken to solve the issues and effective communication with Level 2 and/or Customer.
- Select a sample of research contracts for engagements with external organizations or internal agreements with other business unit(s) within the audit period to determine whether it was executed in alignment with the processes and controls. These contracts include technology licensing, joint research, joint development, data licensing, confidential disclosure, agreement, access agreement, and evaluations.
 - Was an [EZForm](#) completed to initiate an external engagement involving IBM Research?
 - Was the [EZForm](#) approved with accurate information prior to contract signature?
 - Was a Denied Party List (DPL) check performed?
 - Was trade compliance determination completed as required and appropriately approved?
 - Was the contract properly reviewed and authorized according to contract clauses and delegation?
 - Was the contract properly signed? Was IBM signatory authorized per the delegation letter?
 - Were the contractual key non-financial obligations loaded into [Concentrix](#) for tracking till closure?
 - Were deliverables/milestones managed, tracked and executed per terms and conditions?
 - For a DOU, were the scope of work clearly defined with agreed rates of resources?
 - Were there proper labor claiming management, when applicable?

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Government Operations

Objective:

To validate compliance with governmental trade regulations or governmental benefits reporting and calculation. To verify whether there was sufficient oversight of Compliance with Transportation, Entertainment, and Business Amenities (CTEBA) requirements for events and gifts offered.

Risk/Exposure:

Failures to monitor the lab's operations with the government could result in inaccurate government benefits received, fines or penalties (if applicable), regulatory exposure, and reputational damage.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Government Operations

Primary Test: Government Operations (GO001.P)

Objective:

To validate compliance with governmental trade regulations or governmental benefits reporting and calculation. To verify if there was sufficient oversight of CTEBA requirements for events and gifts offered.

Approach:

There are Labs that were involved in government grants and/or tax benefits for the nature of work in the organization/country. Sometimes it could be a benefit to the Lab itself or also for the IBM country. Either way, the involvement of Lab needs to be reviewed in this audit. There are specific audits for the tax/benefit calculation and execution that should not be overlapped. However, the Lab internal process and the input from the Lab to the tax organization should be reviewed.

Additionally, confirm if any gifts or amenities were provided to employees, officials of Government Owned Entities (GOEs) or to commercial parties in certain countries (CPICC) as listed in FIN 168. And, if so, if appropriate CTEBA approvals were obtained.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Financial Management

Objective:

To ensure that accurate financial performance was reported to management on a regular basis. To ensure that measurements were in place to give management visibility of the results of the operations during the period. Finally, ensure that costs were appropriately allocated and fully recovered.

Risk/Exposure:

Inadequate management review may result in financial issues going undetected, root cause analysis not being performed for missed, and timeliness of corrective actions not being taken, leading to potential financial misstatements for IBM.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Financial Management

Primary Test: Intercompany Recovery Rates (FM001.P)

Objective:

To ensure that management controls were in place to guarantee the most accurate recovery rates.

Approach:

For the cost recovery rates, verify:

- Operational parameters, cost trend, next year demand, and estimated spending were obtained timely and analyzed accurately.
- Rate inputs were reviewed by the local financial and worldwide management.
- Rate was approved by the required levels. (local and from the requesting organization)
- Billing was based on the published cost recovery rates.
- All billings were post-approval of the rates.
- Rate changes during the year should be properly approved.
- Rate exceptions given to any specific/unique account(s) should be appropriately approved.
- Exchange rate agreements should be outlined in the documentation along with impacts.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Financial Management

Primary Test: Internal Billing (FM002.P)

Objective:

To ensure that internal billings were processed accurately and in a timely manner and that all costs were properly recovered in accordance with established interlocks and DOUs.

Approach:

Tailor the approach based on the environment:

- To ensure complete understanding of all aspects of the billing process, consider flow-charting the complete billing process, required documents, existing control points. Test different types of cost recovery methodologies: Direct Cost, Shared Infrastructure, Related Services, etc.
- From a listing of ICA and DOUs or from ledger extracts, select a sample and determine if all elements of the ICA or DOU have been billed per the terms. If ICA or DOU data cannot be obtained and ledger extracts are used, request the associated ICA or DOU and all internal billings that have been generated. Focus on quarter-end, year-end activity, high-dollar transactions, and special contracts.
- Review billing reconciliation controls and reports for managing ICAs and DOUs accomplishment. For example, how did the lab finance team monitor the remaining balances to be billed from an ICA compared to the actual billings so far?
- Determine if management had visibility to over limits billing, if root-cause analysis was performed, and if corrective actions were taken to ensure completeness of all billing transactions.
- Verify if billing was accurate, timely, and authorized. Ensure that billings were adequately supported with relevant details, such as headcount, rate, and project information.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Financial Management

Primary Test: Ledger Review (FM003.P)

Objective:

To verify that there was an effective management process to ensure that only properly authorized manual entries and accruals were posted to the lab's general ledger accounts.

Risk/Exposure:

- Ineffective journal entry control may enable employees to conceal irregular entries or clear reconciling items from account analysis by writing them off or otherwise disguising the real nature of the activity.

Approach:

Reconciliations, when performed correctly and on time, are the primary control to identify any differences between the general ledger and the systems which feed it. In addition, the analysis of the accounts would identify if inappropriate or unauthorized transactions were recorded into the general ledger.

The review should be of any journal, accrual, or reconciliation that the audit client has direct requests or impacts on.

Journals

Select a sample of requested journal entries to determine:

- Was the request clear with appropriate documentation and approvals prior to submission to Finance / Accounting for a journal entry to be done into the lab's accounts?
- Did the journal amount agree with backup documentation and enter into the correct account?

Accruals

Select a sample of accrual/provision entries to determine:

- Was the request clear with appropriate documentation and line approvals prior to the request submission to Finance / Accounting for a journal entry to be done?
- Determine if the calculation methodologies were reasonable and were consistent with IBM's accounting guidelines.
- Determine if accruals were reversed on time in the following accounting period, and if actual costs or expenses were recorded as incurred.

Reconciliations

Select a sample of reconciliations to determine:

- Determine if reconciliations were regularly performed as designed.
- Were discrepancies identified and highlighted to management?
- Were root-cause-analyses performed and appropriate actions taken a timely manner?

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Financial Management

Primary Test: Over/Under Recovery Process (FM004.P)

Objective:

To ensure that over/under recovery adjustments arising out of billings at recovery rates were performed accurately, timely and properly approved.

Approach:

Test needs to be done according to the over/under process for the organization. However, the over/under residual treatment needs to be aligned with IBM Finance guidelines or approved instructions.

Note:

The amounts reflected on the balance sheet (B/S) account should only be posted by the zero-out allocation. It needs to be checked whether only the expected allocation entries were recorded on this account. In case of a high over/under, it would be important as well to understand the reason.

According to the Accounting for Cost Centers (CCs) Guidance, at the close of each accounting month, the spending distribution process will allocate 100% of the spending collected in a CC to the appropriate end users. As accurate billing forecast to reflect spending was not easy, there is usually some over/under balance, and this balance was not billed in the period when it occurs. Thus, it is allocated via allocation tool on a reversal base to the B/S account temporarily until it is billed out.

Only balance related to current quarter should be included in the allocations and recorded on the B/S account. To ensure this, proper billing methodology needs to be used, with ICA billings processed at least on quarter basis, using M1 and M2 actuals plus M3 forecast, to keep the unbilled over/under as close to zero as possible. In Q1 the billing related to prior year balance needs to be billed as separate billing using prior year ICA.

Select the permanent adjustment entries processed before year- or quarter-end and check:

- Review performed by the local and worldwide lab chief financial officer (CFO) for the over/under recovery to be adjusted and allocated to geography.
- Geography/worldwide involvement and acknowledgement.
- Billing adjusted by finance analyst against ICA.
- Reconcile the actual over/under allocation with the ledger entries. Analyze the variances.
- Impact of currency exchange rate changes from plan.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Financial Management

Primary Test: Department Expenses (FM005.P)

Objective:

To verify that departments expenses were for a valid IBM business purpose and aligned with corporate instructions, and that there were no unauthorized direct charging of expenses or personal expenses.

Approach:

Select a sample of departmental expenses from those recorded on the ledger. A higher dollar amount parameter may be used based on risk.

Request the supporting documentation for these charges and test for the following attributes:

- Was the expense properly approved?
- Was the expense for a valid business purpose?
- Was the expense fully documented (i.e., a valid supplier invoice)?
- Was the expense reasonable?
- Was the expense charged to the proper account code or correctly allocated through the projects if it was a common cost?
- Were depreciation charges properly registered and allocated through the projects?

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Financial Management

Primary Test: Other income and/or charges (FM006.P)

Objective:

To verify if there were management controls to ensure that financials of other income and/or other charges were accurate and properly maintained and to prevent undetected financial issues or inaccurate financial records.

Approach:

- Query the general ledger to verify whether other income or other charges were recorded and properly accounted for.
- Determine how the organization records other income and charges in the general ledger. For example, some organizations may record other income and/or other charges by department number, others by contract number.
- Assess the impact on gross profit (GP) reporting of correctly reporting charges above / below GP.
- Were other income and/or other charges recorded in the correct period?
- Were there any instances where contract expenses were included in other charges leading to GP being overstated?

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Asset Management

Objective:

To determine whether effective controls were in place for asset management to ensure accurate technical and financial recording and tracking of IBM hardware and software assets from an assessment of the business requirements which may require the transfer of assets from a customer to IBM, purchase, or lease of a new asset and/or reuse of existing assets through disposal. Validating whether existing assets can be reused or not, and a decision to purchase / move an existing asset from one contract / account / business area is made then approvals are obtained to process the order, receive, track physically and financially. Any disposals are managed through a similar approach.

Risk/Exposure:

Ineffective and insufficient monitoring of the lab's assets may lead to assets or information loss, low performance due to unavailability when needed, or incorrect asset and depreciation recording.

1. Inaccurate inventory records, either hardware assets or software licenses, could result in disputes.
2. Poor timeline management to transition an asset to a project could negatively impact the committed project/product delivery schedule.
3. Inaccurate inventory records could lead to loss of assets.
4. Incomplete identification and monitoring of hardware assets may result in missed or delayed decision relating to replacement of assets and asset scrapping and could lead , low performance due to unavailability when needed.
5. Inadequate controls to ensure that IBM assets are adequately protected could result in loss of assets and financial loss.
6. Missing processes to ensure effective actions are taken to investigate and resolve inventory discrepancies could allow lost assets to remain undetected and result in financial loss.
7. Scrapping of assets without the required business and financial approvals and not recording the scrapping of assets could result in unauthorized scrapping of equipment, inaccurate asset records and reporting within IBM and to customers, and increased cost to IBM.
8. Lack of periodic physical inventory checks (book-to-floor (B2F) and floor-to book (F2B)) in accordance with IBM best practices may result in inaccurate asset records, lost and stolen assets remaining unidentified and breach of contracts.
9. Incomplete book-to-book reconciliations could result in inaccurate inventory data and could lead to loss of machines or incomplete financial records.

LABORATORIES AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Asset Management

Primary Test: Asset Management (AM001.P)

Approach:

To determine whether effective controls were in place for asset management to ensure accurate technical and financial recording and tracking of IBM hardware and software assets from acquisition through disposal.

Note: There are two kinds of assets: CIO owned assets and the capital assets (assets purchased and owned by the lab). For the CIO given assets, there is not much to test unless their controls to make sure assets are secured (as they carry confidential information) and information/ownership is kept updated.

Capital assets

- Does a process exist to cover all asset management activities, i.e., Approval, Order, Receiving, Tracking, Updating, Changing, Reporting, End of Asset life?
- Were all capital expenditures appropriately planned and approved for capital assets?
- Was the receipt of the asset handled efficiently? Consider:
 - Were assets signed for receipt, verified in line with the order, checked for damage?
 - What was the escalation process in case of discrepancies?
 - How were incorrect receipts resolved?
- How were assets tracked and recorded once received into IBM?
 - Were asset records updated in the relevant asset repositories, such as Electronic Asset Management Tool (eAMT), with all relevant fields (type, model, serial number, street name, location, owner, user). For the eAMT input, it is WW team responsibility, however, it is the asset owner's responsibility to verify that.
- When physical location of an asset was changed, was there an effective process in place to record the change? Was the change appropriately approved for the change made to the asset database? Was unauthorized change detected for correction?
- Was physical tracking performed on a regular basis? Were discrepancies highlighted? Were root causes identified and actions taken?
- Were (physical) reconciliations performed on a regular basis with discrepancies highlighted? Were appropriate resolution actions (action plan with approval; the remediation action with target resolution dates and action owners) taken? A physical reconciliation can be performed: book-to-floor (B2F) and floor-to book (F2B) validations. It is important to make a mix of lab servers which must be stored in a secure and controlled room and personal computers.
 - Book-to-floor: From the assets universe list (typically from e-AMT), select sample to physically review and make sure the asset is found, the correct owner is assigned, and correct location is indicated in the system.
 - Floor-to-book: During the walk review to find the assets of the B2F, select assets physically, take note of the machine type and serial number and then validate if they are in the systems with the correct information in.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Procurement

Objective:

Were Procurement process correctly applied for all the purchases? Were there adequate controls over the process for approving the commitment of IBM funds to external suppliers who were selected based on the criteria set forth in the Procurement Requirements and Practices booklet?

Risk/Exposure:

Failure to properly control the approval of commitments can create excess expenditures, legal problems, vendor relations exposures, and can lead to fraud.

LABORATORIES
AUDIT PROGRAM #50-05-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Procurement

Primary Test: Procurement (PR001.P)

Approach:

Since procurement owns most of the process, these tests are to ensure the requests and approvals required from the line team are being adequately reviewed. Select a sample of top vendors and purchase orders to confirm effective compliance with the established guidelines.

Overall Procurement focus

- Review universe files of purchase order (POs), engineering change requests (ECRs), PO Exempts, and invoice-only-invoices (IOIs) during the audit period. Repeating requests for payment to the same supplier and/or from the same requestor could be a sample selection criterion.
 - Were all procurement requisitions in line with regulations and processes?
 - Were non-PO items (IOIs) which did not require procurement involvement justified, approved, and processed appropriately?
- For bypasses identified during the audit period, verify if their action plans were effective to avoid repeat bypasses? If any are repeat offenders, did the action reflect that?
- Was there appropriate vendor management process, such as onboard, service-level agreement, and separation? Were the requirements executed according to the process?